PROYECTO FINAL · SEGURIDAD INFORMÁTICA 2026

Fase 6

Cumplimiento Normativo y Hardening

Evaluación SCA, documentación de hallazgos y remediación verificada sobre los tres agentes del laboratorio Wazuh.

Plataforma	Wazuh 4.9.2 · Manager, Indexer y Dashboard
Agentes evaluados	`agent-linux` · `agent-db` · `agent-windows`
Línea base	02/11/2026
Medición post-hardening	03/11/2026
Evidencia	Seis exportaciones CSV de SCA (tres antes, tres después)
Versión	1.0 · documento de entrega

CONTENIDO DEL INFORME

01 Compliance y marcos normativos
02 Metodología y resultados SCA
03 Hallazgos y remediación
04 Hardening aplicado
05 Verificación y brechas
06 Conclusiones y anexos

Contenido

Resumen ejecutivo

Resumen de resultados

1. Introducción y alcance

1.1 Propósito
1.2 Alcance
1.3 Relación con F5 y orden de las mediciones
1.4 Fuentes de evidencia

2. Marco de referencia y metodología

2.1 Qué es el SCA de Wazuh
2.2 Benchmarks y versiones
2.3 Módulo de compliance: SCA y Regulatory Compliance
2.4 Método antes/después
2.5 Limitaciones metodológicas

3. Módulo de compliance (requisito 1)

3.1 Cómo se revisó
3.2 Cobertura de frameworks en las políticas SCA
3.3 Lectura por framework
3.4 GDPR: cobertura desde Regulatory Compliance
3.5 Cómo revisarlo en el dashboard

4. Resultados del SCA inicial (requisito 2)

4.1 Tabla global de la línea base
4.2 agent-linux: Ubuntu 22.04 LTS
4.3 agent-db: Debian 13 con política Debian 11
4.4 agent-windows: Windows Server 2022

5. Hallazgos y planes de remediación (requisito 3)

5.1 Resumen de los 14 hallazgos
5.2 Fichas de hallazgos
5.3 Trazabilidad con los ataques de F5

6. Hardening aplicado (requisito 4)

6.1 Criterios de selección
6.2 Linux: configuración SSH verificada
6.3 Linux: AppArmor y permisos
6.4 Windows: políticas de grupo aplicadas
6.5 Lo que deliberadamente no se aplicó
6.6 Verificación y control de cambios

7. Resultados después del hardening (requisito 4, verificación)

7.1 Antes y después por agente
7.2 Controles ganados
7.3 Regresiones y estabilidad
7.4 Cobertura por framework
7.5 Distribución de fallos por sección
7.6 Estado de los hallazgos
7.7 Interpretación

8. Brechas residuales y hoja de ruta

- 8.1 Linux: deuda estructural
- 8.2 Windows: plantillas administrativas y auditoría
- 8.3 agent-db: la sombra de Debian 13
- 8.4 Matriz de priorización
- 8.5 Riesgo residual y controles compensatorios
- 8.6 Trabajo futuro

9. Conclusiones

- 9.1 Cumplimiento de los cinco requisitos
- 9.2 Resultados principales
- 9.3 Alcance de las conclusiones

10. Referencias

Anexo A: Inventario de evidencia

Anexo B: Controles ganados

- B.1 agent-linux
- B.2 agent-db
- B.3 agent-windows

Anexo C: Benchmarks y PDFs locales

Anexo D: Exportación desde el dashboard

- D.1 Qué exporta Wazuh 4.9.2
- D.2 Procedimiento de exportación CSV
- D.3 Los PDF de `Wazuh-Reportes/`

Anexo E: Glosario

Resumen ejecutivo

Este documento cierra la Fase 6 del proyecto: **Cumplimiento Normativo y Hardening**. Se apoya en las exportaciones reales del módulo SCA de Wazuh 4.9.2 [4] sobre los tres agentes del laboratorio, en una línea base tomada el 02/11/2026 y en una segunda medición tomada después de aplicar el hardening, el 03/11/2026.

El entregable se organiza alrededor de cinco requisitos. La tabla siguiente resume dónde se cumple cada uno y con qué evidencia.

#	Requisito	Dónde se cumple	Evidencia principal	Estado
1	Revisar el módulo de compliance (PCI DSS, GDPR, HIPAA, NIST 800-53)	Sección 3	Columna `Compliance` de los CSV + vista SCA del dashboard	Resuelto
2	Ejecutar SCA sobre todos los agentes	Sección 4	6 CSV: 3 antes + 3 después	Resuelto
3	Documentar ≥ 10 hallazgos con plan de remediación	Sección 5	14 fichas H-01 a H-14	Resuelto
4	Aplicar hardening CIS Level 1	Secciones 6 y 7	23 controles ganados, 0 regresiones	Resuelto
5	Generar y exportar el reporte ejecutivo de cumplimiento	Este documento y anexo D	Seis CSV del SCA (tres antes, tres después) + este PDF	Resuelto

El reporte ejecutivo se construyó a partir de las seis exportaciones CSV del módulo SCA del dashboard. El anexo D documenta el procedimiento de exportación.

Resumen de resultados

Agente	SO	Política	Controles	Antes P/F	Antes	Después P/F	Después	Δ
`agent-linux`	Ubuntu 22.04 LTS	cis_ubuntu22-04	182	70/110	38.9%	78/102	43.3%	+4.4 pp
`agent-db`	Debian 13 (trixie)	cis_debian11	198	73/103	41.5%	82/94	46.6%	+5.1 pp
`agent-windows`	Windows Server 2022	cis_win2022	359	141/218	39.3%	147/212	40.9%	+1.6 pp

En conjunto se evaluaron **739 controles** (suma de los tres agentes). Los aprobados pasaron de **284 a 307** y los fallidos de **431 a 408**. Se ganaron **23 controles** y no se perdió ninguno: **0 regresiones**.

Indicador	Antes	Después	Δ
Controles aprobados	284	307	+23
Controles fallidos	431	408	-23
No aplicables	24	24	0
Hallazgos resueltos	—	11 de 14	—
Hallazgos parciales	—	0 de 14	—
Hallazgos pendientes	—	3 de 14	—

Lectura ejecutiva.

- El hardening cerró los vectores de acceso remoto más importantes: permisos de `sshd_config`, `PermitRootLogin`, `MaxAuthTries`, `MaxStartups`, `LoginGraceTime`, reenvío X11/TCP y confinamiento de AppArmor. Son controles que reducen la superficie del ataque de fuerza bruta de F5 (T1110.001), aunque la causa raíz de esa demo fue una contraseña débil asignada a propósito.
- En Windows se cerraron las políticas de contraseña, bloqueo de cuenta e inactividad de sesión. El score subió poco porque el agente tiene 359 controles y la sección 18 (plantillas administrativas) concentra 219, de los cuales 161 siguen fallando.
- Los tres hallazgos pendientes son estructurales o requieren una ventana de cambio: `AllowUsers`, contraseña de GRUB, y particiones separadas para `/var/log` y `/var/log/audit`. Ninguno invalida el hardening aplicado; quedan priorizados en la sección 8.
- El resultado global sigue lejos de estar listo para producción: 43.3%, 46.6% y 40.9% miden configuración y dejan fuera cualquier certificación formal.

1. Introducción y alcance

1.1 Propósito

La Fase 6 cubre cinco áreas: revisión del módulo de compliance, ejecución de SCA sobre todos los agentes, documentación de al menos diez hallazgos con su plan de remediación, hardening básico siguiendo CIS Level 1, y el reporte ejecutivo de cumplimiento. Este documento cubre las cinco, con evidencia verificable y con una separación explícita entre lo que se midió, lo que se aplicó y lo que quedó pendiente.

1.2 Alcance

El alcance son los tres agentes del laboratorio que participan del escenario empresarial. La tabla siguiente fija la identidad de cada uno y la política SCA que se le aplicó.

Agente	IP	SO real	Rol	Policy ID	Benchmark
`agent-linux`	192.168.100.20	Ubuntu 22.04 LTS	Servidor web Apache + PHP	`cis_ubuntu22-04`	CIS Ubuntu Linux 22.04 LTS Benchmark v1.0.0 (2022-08-30)
`agent-db`	192.168.100.40	Debian 13 (trixie)	PostgreSQL 17.11 + SSH	`cis_debian11`	CIS Debian Linux 11 Benchmark v1.0.0 (2022-09-22)
`agent-windows`	192.168.100.30	Windows Server 2022	Active Directory + SMB	`cis_win2022`	CIS Microsoft Windows Server 2022 Benchmark v2.0.0 (2023-04-14)

Nota sobre el agente MISP. El laboratorio incorporó un agente auxiliar MISP (`misp-agent-linux`, 192.168.100.11) para enriquecimiento de threat intelligence. No forma parte del alcance de F6: es un servicio de apoyo, no una carga de trabajo del escenario, y no se le aplicó hardening. Se registra como trabajo futuro en la sección 8.6.

1.3 Relación con F5 y orden de las mediciones

La evidencia de ataques de F5 [14] se capturó **antes** del hardening. Eso explica por qué los ataques funcionaron: el laboratorio estaba en su estado basal. El orden fue deliberado: primero se demostró el ataque y la detección, después se endureció el sistema y se midió el efecto. Si se repitiera la demo de fuerza bruta, los controles nuevos (`MaxAuthTries`, `PermitRootLogin`, límites de conexión) reducirían la velocidad y la superficie del ataque, aunque una contraseña débil seguiría siendo explotable. Esa diferencia entre hardening y gestión de credenciales es parte de la lección de F6.

1.4 Fuentes de evidencia

Fuente	Uso en este informe
`Configuration-Assestments/checks_*.csv`	Línea base SCA del 02/11/2026
`Configuration-Assestments-PostHardening/checks_*.csv`	Medición post-hardening del 03/11/2026
Dashboard Wazuh 4.9.2	Origen de los seis CSV; vista SCA por agente y vista Regulatory Compliance
YAML de políticas de Wazuh	Fuente autoritativa de la versión del benchmark y de los IDs CIS
`F6_Assets/analysis.json`	Datos congelados que alimentan todas las tablas y gráficos

La evidencia de lo aplicado es el CSV post-hardening: el SCA volvió a evaluar la configuración real, y esos resultados son los que se usan en las secciones 6 y 7.

2. Marco de referencia y metodología

2.1 Qué es el SCA de Wazuh

El módulo **Security Configuration Assessment (SCA)** [1] evalúa la configuración de un endpoint contra una política escrita en YAML. Cada política contiene checks con un ID, un título, una descripción, una lógica de evaluación y un bloque de cumplimiento. El agente ejecuta la política, envía el resultado al manager y el dashboard lo agrega por agente y por política.

Los estados posibles de un check son `passed`, `failed` y `not applicable`. El puntaje que muestra el dashboard se calcula así:

```
score = passed / (passed + failed) × 100
```

Los `not applicable` se excluyen del denominador. Es la fórmula que se usa en todo este informe para que los números coincidan con el dashboard. Más adelante se explica por qué esa exclusión importa al comparar agentes.

SCA **no es un escáner de vulnerabilidades**. El Vulnerability Detector busca CVEs en paquetes; SCA busca desviaciones de configuración. Se complementan: un sistema puede no tener CVEs conocidos y aun así tener SSH con login de root habilitado.

2.2 Benchmarks y versiones

La versión del benchmark importa porque los IDs CIS cambian entre versiones; el mapeo autoritativo es el YAML de la política que Wazuh ejecutó. La tabla siguiente fija esa correspondencia.

Agente	Policy ID	Benchmark	Versión	SO real	Coincidencia
`agent-linux`	`cis_ubuntu22-04`	CIS Ubuntu Linux 22.04 LTS Benchmark	v1.0.0 (2022-08-30)	Ubuntu 22.04 LTS	Coincidencia exacta entre la política y el sistema operativo.
`agent-db`	`cis_debian11`	CIS Debian Linux 11 Benchmark	v1.0.0 (2022-09-22)	Debian 13 (trixie)	Política Debian 11 adaptada a Debian 13: se cambió el requirements de 11. a 13. Resultados indicativos, no certificación Debian 13.
`agent-windows`	`cis_win2022`	CIS Microsoft Windows Server 2022 Benchmark	v2.0.0 (2023-04-14)	Windows Server 2022	Benchmark estándar. No es STIG ni Stand-alone.

Mapeo de IDs. Wazuh distribuye la política `cis_ubuntu22-04.yml` basada en CIS Ubuntu Linux 22.04 LTS Benchmark v1.0.0 (2022-08-30) [5], `cis_debian11.yml` basada en CIS Debian Linux 11 Benchmark v1.0.0 (2022-09-22) [6] y `cis_win2022.yml` basada en CIS Microsoft Windows Server 2022 Benchmark v2.0.0 (2023-04-14) [7], incluidas en el ruleset de Wazuh [3]. Para mapear los IDs del CSV, el YAML es la fuente correcta.

2.3 Módulo de compliance: SCA y Regulatory Compliance

Wazuh expone el cumplimiento en dos capas distintas. La primera es **SCA**: cada check lleva un arreglo `Compliance` con referencias a PCI DSS, HIPAA, NIST 800-53, ISO 27001, SOC 2, CMMC, CIS CSC y MITRE ATT&CK. Esas referencias están en la columna `Compliance` de los CSV. La segunda es **Regulatory Compliance** [2]: un módulo global que agrupa alertas por framework a partir de las reglas del manager, no de los checks de SCA.

Capa	Qué evalúa	Dónde se ve	Uso en este informe
SCA	Configuración del endpoint contra un benchmark CIS	Dashboard → agente → Security Configuration Assessment	Resultados, scores y hallazgos
Regulatory Compliance	Alertas del manager mapeadas a requisitos	Dashboard → Regulatory Compliance → framework	Contexto de PCI DSS, HIPAA, NIST y GDPR

Ejemplo real de un check y sus etiquetas. El check `5.2.7` de `agent-linux` ("Ensure SSH root login is disabled") trae, entre otras, estas referencias: `cis` 5.2.7, `cis_csc_v8` 5.4, `cmmc_v2.0` AC.L2-3.1.5/AC.L2-3.1.6/AC.L2-3.1.7/SC.L2-3.13.3, `iso_27001-2013` A.9.2.3, `nist_sp_800-53` AC-6(2)/AC-6(5), `pci_dss_v3.2.1` 7.1/7.1.1/7.1.2/7.1.3, `soc_2` CC6.1/CC6.3 y `mitre_techniques` T1021. Esa es la trazabilidad que el dashboard muestra al expandir un check.

2.4 Método antes/después

La comparación se hizo por **ID CIS**. Para cada agente se cargaron los dos CSV, se indexaron por el valor `cis` del arreglo `Compliance` y se clasificó cada control en cuatro categorías: se mantuvo aprobado, se mantuvo fallido, se ganó (`failed → passed`) o se perdió (`passed → failed`). Los controles que no aparecen en una de las dos mediciones se reportan como no comparables; en este caso no hubo diferencias de inventario entre antes y después.

La línea base es del 02/11/2026. El hardening se aplicó el 03/11/2026. La política y el agente no cambiaron entre mediciones.

2.5 Limitaciones metodológicas

1. **Level 1 y Level 2 mezclados.** Las políticas incluyen checks de ambos perfiles. El porcentaje global no es un porcentaje de cumplimiento CIS Level 1. En la sección 6 se indica qué se aplicó y qué excepción Level 2 se incluyó.
2. **Debian 13 con política Debian 11.** `agent-db` corre Debian 13 (trixie), pero Wazuh no tiene una política CIS Debian 13. Se adaptó `cis_debian11.yml` cambiando el `requirements` de `11.` a `13.`. Los resultados son indicativos: miden controles de Debian 11 sobre un sistema Debian 13, no una certificación Debian 13.
3. **N/A que no son equivalentes.** `agent-db` tiene 22 `not applicable`, 21 de ellas en la sección 4 porque la política no puede evaluar las reglas de auditoría cuando `auditd` no está instalado. `agent-linux`, en cambio, marca esas mismas comprobaciones como `failed`. Al excluir los N/A, el score de `agent-db` queda inflado en relación con `agent-linux`. Si se contaran esas 21 como fallidas, `agent-db` estaría en 37.1% antes y 41.6% después, no en 41.5% y 46.6%. Se mantiene la fórmula del dashboard por consistencia, pero la comparación entre agentes debe leerse con esta advertencia.
4. **El score no pondera por riesgo.** Un control de bajo impacto vale lo mismo que uno crítico. Un 43% indica que 43 de cada 100 controles evaluados pasaron.
5. **SCA es configuración, no operación.** Un control puede pasar y el servicio puede estar mal operado, o al revés. SCA no reemplaza pruebas de penetración, monitoreo runtime ni una auditoría formal.

3. Módulo de compliance (requisito 1)

3.1 Cómo se revisó

La revisión se hizo sobre la evidencia primaria, no sobre una captura de pantalla: se abrió la columna `Compliance` de los seis CSV y se verificó que cada check tuviera referencias a los frameworks. Después se contrastó con la vista SCA del dashboard, donde cada check expandido muestra esas mismas referencias, y con la vista Regulatory Compliance, que agrupa alertas por framework.

El resultado es que el módulo **no se "habilita" aparte**: viene integrado en cada check de SCA. Lo que sí es separado es la vista Regulatory Compliance, que trabaja sobre alertas del manager y no sobre resultados de SCA. Esta distinción es la clave para entender por qué PCI DSS, HIPAA y NIST aparecen en los CSV, y GDPR no.

3.2 Cobertura de frameworks en las políticas SCA

La tabla siguiente cuenta cuántos checks de cada agente llevan al menos una referencia al framework. Un mismo check puede aparecer en varios frameworks, así que las columnas no suman el total de controles del agente.

Framework	agent-linux	agent-db	agent-windows
PCI DSS v4.0	160	158	202
PCI DSS v3.2.1	161	159	219
HIPAA	83	84	38
NIST 800-53	131	131	152
ISO 27001	168	164	230
SOC 2	158	154	209

Framework	agent-linux	agent-db	agent-windows
CMMC v2.0	167	166	206
CIS CSC v8	171	168	247

Los frameworks con más cobertura son CIS CSC v8 [13], ISO 27001 y PCI DSS. Los de menor cobertura son HIPAA y NIST 800-53, porque sus controles se concentran en un subconjunto de checks. La cobertura mide representación: un framework puede tener pocos checks y aun así estar bien cubierto en los controles críticos.

3.3 Lectura por framework

- **PCI DSS** [8] (v4.0 y v3.2.1; en `agent-db` sin la letra `v` en la clave, unificada en el análisis) cubre acceso, autenticación, registro, segmentación y protección de datos. Los controles de SSH y de contraseñas endurecidos impactan directo en acceso (7.x) y autenticación (8.x); las particiones y la retención de logs, pendientes, son su deuda principal.
- **HIPAA** [9] concentra sus checks en control de acceso, auditoría y protección de la información. La cobertura es más alta en `agent-windows` porque sus políticas de contraseña, bloqueo e inactividad tienen mapeo directo; en los Linux la deuda está en auditoría (`auditd`) y separación de logs.
- **NIST SP 800-53** [10] tiene cobertura media-baja (131/131/152 checks), por debajo de PCI DSS, ISO 27001 y CIS CSC. Los controles `AC-*` y `AU-*` son los que más se movieron con el hardening; la política CIS cubre configuración, no los procesos organizacionales que NIST también exige.

La evolución antes/después de los ocho frameworks está en la sección 7.4.

3.4 GDPR: cobertura desde Regulatory Compliance

Los seis CSV no tienen la clave `gdpr`. No es un error de parsing: las políticas SCA usadas no mapean GDPR. Wazuh sí soporta GDPR, pero en la capa de Regulatory Compliance, a través de reglas del manager etiquetadas con `gdpr_*`, no dentro de estos checks de SCA. Por eso no se puede reportar un "% GDPR" a partir de los CSV.

Para no dejar el requisito sin respuesta, se construyó una **matriz indicativa** que cruza artículos del GDPR [11] con controles aplicados y capacidades de Wazuh.

Artículo GDPR	Qué exige	Evidencia en el laboratorio	Estado
Art. 25: Protección por diseño y por defecto	Minimizar datos y aplicar controles técnicos desde el diseño	Hardening SSH, AppArmor, mínimo privilegio, bloqueo de cuentas	Parcial
Art. 30: Registro de actividades de tratamiento	Mantener un registro de tratamientos	No cubierto por SCA; requiere documentación organizacional	Pendiente
Art. 32: Seguridad del tratamiento	Confidencialidad, integridad, disponibilidad y resiliencia; pruebas periódicas	Control de acceso, AppArmor, políticas de contraseña, SCA periódico, FIM	Parcial
Art. 33-34: Notificación de brechas	Detectar, evaluar y notificar brechas	Alertas Wazuh, Active Response y F5; detección efectiva 50.0% y específica 33.3%, con brecha de FIM	Parcial
Art. 35: Evaluación de impacto	DPIA para tratamientos de alto riesgo	No cubierto; requiere proceso legal	Pendiente

Conclusión de GDPR. El laboratorio tiene controles técnicos que contribuyen a los artículos 25 y 32, y capacidades de detección que ayudan al 33-34.

3.5 Cómo revisarlo en el dashboard

```
Wazuh Dashboard → Agents → seleccionar agente
  → Security Configuration Assessment → política CIS
  → expandir un check → ver referencias de cumplimiento

Wazuh Dashboard → Regulatory Compliance → seleccionar framework
  → PCI DSS / HIPAA / NIST 800-53 / GDPR → alertas agrupadas por requisito
```

La primera ruta muestra la trazabilidad por check (la que está en los CSV). La segunda muestra la agrupación por alertas (la que alimenta Regulatory Compliance).

4. Resultados del SCA inicial (requisito 2)

4.1 Tabla global de la línea base

Agente	Controles	Aprobados	Fallidos	N/A	Score
`agent-linux`	182	70	110	2	38.9%
`agent-db`	198	73	103	22	41.5%
`agent-windows`	359	141	218	0	39.3%

Los tres agentes arrancan en un rango bajo, entre 38.9% y 41.5%. Es lo esperable en una VM recién instalada: el benchmark CIS es exigente y muchas de sus recomendaciones no vienen aplicadas por defecto. El objetivo de F6 fue medir, priorizar y demostrar una mejora verificable.

4.2 agent-linux: Ubuntu 22.04 LTS

`agent-linux` tiene **182 controles** y un score inicial de **38.9%** (70 aprobados, 110 fallidos, 2 N/A). Es el agente con la política exacta para su sistema operativo: Ubuntu 22.04 LTS con `cis_ubuntu22-04` v1.0.0.

Sec.	Nombre	Total	Aprob.	Fall.	N/A	Cumpl.
1	Configuración inicial	45	11	34	0	24.4%
2	Políticas locales / servicios	28	18	9	1	66.7%
3	Red	17	2	15	0	11.8%
4	Registro y auditoría	35	10	24	1	29.4%
5	Acceso y autenticación	45	17	28	0	37.8%
6	Mantenimiento del sistema	12	12	0	0	100.0%

Dónde se concentran los fallos.

Sec.	Nombre	Fallidos	Total	% fallo
1	Configuración inicial	34	45	75.6%
5	Acceso y autenticación	28	45	62.2%
4	Registro y auditoría	24	35	68.6%
3	Red	15	17	88.2%
2	Políticas locales / servicios	9	28	32.1%

La sección 1 (configuración inicial) es la más grande: 34 fallos, dominados por particiones separadas (`/tmp`, `/var`, `/var/tmp`, `/home`, `/var/log`, `/var/log/audit`) y opciones de montaje. La sección 4 (auditoría) tiene 24 fallos porque `auditd` no está instalado. La sección 3 (red) tiene 15 fallos porque no hay un firewall activo con política deny. La sección 5 (acceso) tiene 28 fallos, pero ahí estaban los controles SSH que después se cerraron.

4.3 agent-db: Debian 13 con política Debian 11

`agent-db` tiene **198 controles** y un score inicial de **41.5%** (73 aprobados, 103 fallidos, 22 N/A). Es el agente con la política adaptada: Debian 13 (trixie) evaluado con `cis_debian11` v1.0.0. Los 22 N/A son la huella de esa adaptación y de la ausencia de `auditd`.

Sec.	Nombre	Total	Aprob.	Fall.	N/A	Cumpl.
1	Configuración inicial	47	14	33	0	29.8%
2	Políticas locales / servicios	30	22	8	0	73.3%
3	Red	20	4	16	0	20.0%
4	Registro y auditoría	45	12	12	21	50.0%
5	Acceso y autenticación	45	15	29	1	34.1%
6	Mantenimiento del sistema	11	6	5	0	54.5%

Dónde se concentran los fallos.

Sec.	Nombre	Fallidos	Total	% fallo
1	Configuración inicial	33	47	70.2%
5	Acceso y autenticación	29	45	64.4%
3	Red	16	20	80.0%
4	Registro y auditoría	12	45	26.7%
2	Políticas locales / servicios	8	30	26.7%

El patrón es parecido al de `agent-linux`: particiones, firewall y auditoría. Además, `agent-db` falla permisos de `/etc/shadow`, `/etc/shadow-`, `/etc/gshadow` y `/etc/gshadow-` (sección 6), y tiene 29 fallos en la sección 5, donde también estaban los controles SSH. Los 21 N/A de auditoría no son una ventaja: son una limitación de la política, explicada en la sección 2.5.

4.4 agent-windows: Windows Server 2022

`agent-windows` tiene **359 controles** y un score inicial de **39.3%** (141 aprobados, 218 fallidos, 0 N/A). Es el agente con más controles y el que más distorsiona la lectura del score: la sección 18 (plantillas administrativas) tiene 219 checks, el 61% del total del agente.

Sec.	Nombre	Total	Aprob.	Fall.	N/A	Cumpl.
1	Configuración inicial	8	3	5	0	37.5%
2	Políticas locales / servicios	70	46	24	0	65.7%
5	Acceso y autenticación	2	0	2	0	0.0%
9	Firewall y red	26	9	17	0	34.6%
17	Auditoría avanzada	34	25	9	0	73.5%
18	Plantillas administrativas	219	58	161	0	26.5%

Dónde se concentran los fallos.

Sec.	Nombre	Fallidos	Total	% fallo
18	Plantillas administrativas	161	219	73.5%
2	Políticas locales / servicios	24	70	34.3%
9	Firewall y red	17	26	65.4%
17	Auditoría avanzada	9	34	26.5%
1	Configuración inicial	5	8	62.5%
5	Acceso y autenticación	2	2	100.0%

La sección 18 concentra 161 de los 218 fallos. Muchos son plantillas administrativas de navegador, telemetría, pantalla de bloqueo, LAPS y SMBv1. La sección 9 (firewall) tiene 17 fallos, casi todos de logging; la sección 2 (políticas locales) tiene 24, incluidos Guest, mensaje legal y LDAP; la sección 17 (auditoría avanzada) tiene 9. La sección 5 (Print Spooler) tiene 2.

La evolución de la cobertura por framework (antes → después del hardening) se muestra una sola vez, en la sección 7.4, para no repetir la misma tabla.

5. Hallazgos y planes de remediación (requisito 3)

5.1 Resumen de los 14 hallazgos

Se documentaron **14 hallazgos**. Cada uno tiene ID, controles CIS asociados, agentes afectados, severidad, riesgo, remediación y estado verificado contra el CSV post-hardening. La tabla siguiente es el índice; las fichas completas vienen después.

#	Hallazgo	CIS	Agentes	Severidad	Estado
H-01	Permisos de /etc/ssh/sshd_config no restringidos	`5.2.1`	`agent-linux`, `agent-db`	Alta	Resuelto
H-02	Acceso SSH no limitado a usuarios o grupos autorizados	`5.2.4`	`agent-linux`, `agent-db`	Alta	Pendiente
H-03	Login directo de root por SSH habilitado	`5.2.7`	`agent-linux`, `agent-db`	Alta	Resuelto
H-04	MaxAuthTries no limitado a 4 o menos	`5.2.18`	`agent-linux`, `agent-db`	Alta	Resuelto
H-05	Límites de conexiones y tiempo de gracia SSH no configurados	`5.2.19`, `5.2.21`	`agent-linux`, `agent-db`	Media	Resuelto
H-06	Reenvío X11 y TCP habilitado	`5.2.12`, `5.2.16`	`agent-linux`, `agent-db`	Media	Resuelto
H-07	Sin contraseña en el bootloader (GRUB)	`1.4.1`	`agent-linux`, `agent-db`	Alta	Pendiente
H-08	AppArmor no instalado o perfiles no enforcing	`1.6.1.1`, `1.6.1.4`	`agent-linux`, `agent-db`	Alta	Resuelto
H-09	/var/log y /var/log/audit no son particiones separadas	`1.1.5.1`, `1.1.6.1`	`agent-linux`, `agent-db`	Media	Pendiente

#	Hallazgo	CIS	Agentes	Severidad	Estado
H-10	Longitud mínima de contraseña menor a 14 caracteres	`1.1.4`	`agent-windows`	Alta	Resuelto
H-11	Política de bloqueo de cuenta ausente o débil	`1.2.1`, `1.2.2`, `1.2.4`	`agent-windows`	Alta	Resuelto
H-12	Cuenta Guest habilitada	`2.3.1.2`	`agent-windows`	Media	Resuelto
H-13	Sin límite de inactividad de sesión	`2.3.7.3`	`agent-windows`	Media	Resuelto
H-14	Mensaje legal de inicio de sesión incompleto	`2.3.7.4`, `2.3.7.5`	`agent-windows`	Media	Resuelto

Resumen de estado: 11 resueltos y 3 pendientes. Los pendientes son los que requieren una ventana de cambio, una decisión de negocio o una reinstalación.

5.2 Fichas de hallazgos

Cada ficha indica el riesgo, la remediación aplicada o pendiente, y el resultado verificado contra el CSV post-hardening. El estado antes/después por control, agente y sección ya está en las tablas de las secciones 4.2-4.4 y 7.1-7.2; estas fichas no lo repiten.

H-01: Permisos de /etc/ssh/sshd_config no restringidos

CIS: `5.2.1` · **Severidad:** Alta · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Resuelto

Riesgo. El archivo de configuración SSH era legible por usuarios no privilegiados, exponiendo parámetros de autenticación. **Remediación.** `chown root:root /etc/ssh/sshd_config && chmod og-rwx /etc/ssh/sshd_config`; aprobado en ambos agentes tras el hardening.

H-02: Acceso SSH no limitado a usuarios o grupos autorizados

CIS: `5.2.4` · **Severidad:** Alta · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Pendiente

Riesgo. Cualquier cuenta válida puede intentar autenticarse por SSH; amplía la superficie de fuerza bruta (T1110.001). **Remediación.** Definir `AllowUsers` / `AllowGroups` y recargar SSH; sigue fallido en ambos agentes, priorizado en 8.4.

H-03: Login directo de root por SSH habilitado

CIS: `5.2.7` · **Severidad:** Alta · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Resuelto

Riesgo. Permite ataques de fuerza bruta contra la cuenta más privilegiada del sistema. **Remediación.** `PermitRootLogin no`; usar una cuenta administrativa y sudo/su. Aprobado en ambos agentes.

H-04: MaxAuthTries no limitado a 4 o menos

CIS: `5.2.18` · **Severidad:** Alta · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Resuelto

Riesgo. Permite probar muchas contraseñas en una sola conexión SSH. **Remediación.** `MaxAuthTries 4` en sshd_config; aprobado en ambos agentes.

H-05: Límites de conexiones y tiempo de gracia SSH no configurados

CIS: `5.2.19`, `5.2.21` · **Severidad:** Media · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Resuelto

Riesgo. Conexiones sin autenticar pueden consumir recursos; una ventana de gracia larga facilita la fuerza bruta. **Remediación.** `MaxStartups 10:30:60` y `LoginGraceTime 60`; ambos controles aprobados en ambos agentes.

H-06: Reenvío X11 y TCP habilitado

CIS: `5.2.12`, `5.2.16` · **Severidad:** Media · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Resuelto

Riesgo. Amplía la superficie de ataque; puede permitir pivote o exfiltración si una cuenta se compromete. **Remediación.** `X11Forwarding no` y `AllowTcpForwarding no`; ambos controles aprobados en ambos agentes.

H-07: Sin contraseña en el bootloader (GRUB)

CIS: `1.4.1` · **Severidad:** Alta · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Pendiente

Riesgo. Acceso físico o a la consola permite editar el arranque y obtener una shell de root, evadiendo la autenticación. **Remediación.** `grub-mkpasswd-pbkdf2`, hash en `/etc/grub.d/40_custom`, `update-grub`; sigue fallido en ambos agentes, requiere ventana de mantenimiento (8.4).

H-08: AppArmor no instalado o perfiles no enforcing

CIS: `1.6.1.1`, `1.6.1.4` · **Severidad:** Alta · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Resuelto

Riesgo. Sin confinamiento de procesos, un servicio comprometido (por ejemplo `consultas.php`) tiene acceso más amplio al sistema. **Remediación.** Instalar `apparmor`/`apparmor-utils` y poner los perfiles en enforcing con `aa-enforce`. Ya estaba instalado en `agent-linux`; ambos agentes terminan con los perfiles en enforcing.

H-09: /var/log y /var/log/audit no son particiones separadas

CIS: `1.1.5.1`, `1.1.6.1` · **Severidad:** Media · **Agentes:** `agent-linux`, `agent-db` · **Estado:** Pendiente

Riesgo. Un atacante puede llenar el disco de logs y afectar la disponibilidad; dificulta retención y aislamiento de auditoría. **Remediación.** Requiere repartición o reinstalación; mientras tanto, rotación de logs y envío remoto. Sigue fallido en ambos agentes, incluido como rebuild en 8.4.

H-10: Longitud mínima de contraseña menor a 14 caracteres

CIS: `1.1.4` · **Severidad:** Alta · **Agentes:** `agent-windows` · **Estado:** Resuelto

Riesgo. Contraseñas cortas son más fáciles de forzar por fuerza bruta. **Remediación.** GPO `Minimum password length = 14`; aprobado.

H-11: Política de bloqueo de cuenta ausente o débil

CIS: `1.2.1`, `1.2.2`, `1.2.4` · **Severidad:** Alta · **Agentes:** `agent-windows` · **Estado:** Resuelto

Riesgo. Permite intentos ilimitados de fuerza bruta contra cuentas de Windows. **Remediación.** GPO: duración de bloqueo = 15 min, umbral = 5 intentos, reinicio de contador = 15 min; los tres controles aprobados.

H-12: Cuenta Guest habilitada

CIS: `2.3.1.2` · **Severidad:** Media · **Agentes:** `agent-windows` · **Estado:** Resuelto

Riesgo. Puerta de entrada innecesaria y cuenta sin trazabilidad individual. **Remediación.** GPO `Guest account status = Disabled`. Verificado por inspección directa del sistema el 04/11/2026 (`Get-LocalUser Guest` → `Enabled: False`).

H-13: Sin límite de inactividad de sesión

CIS: `2.3.7.3` · **Severidad:** Media · **Agentes:** `agent-windows` · **Estado:** Resuelto

Riesgo. Una sesión desatendida queda expuesta indefinidamente. **Remediación.** GPO `Machine inactivity limit = 900`; aprobado.

H-14: Mensaje legal de inicio de sesión incompleto

CIS: `2.3.7.4`, `2.3.7.5` · **Severidad:** Media · **Agentes:** `agent-windows` · **Estado:** Resuelto

Riesgo. Falta la advertencia legal de inicio de sesión, requisito común de PCI DSS/HIPAA. **Remediación.** GPO: `Message title` y `Message text`, ambos configurados. Verificado por inspección directa del sistema el 04/11/2026 (registro `legalnoticecaption`/`legalnoticetext` con contenido).

Los hallazgos pendientes (H-02, H-07, H-09) están priorizados junto con el resto de los controles residuales en la matriz de la sección 8.4.

5.3 Trazabilidad con los ataques de F5

La tabla cruza cada hallazgo con la técnica de ATT&CK correspondiente [12].

Hallazgo	Ataque o técnica de F5	Relación
H-02, H-03, H-04, H-05	T1110.001: fuerza bruta SSH (`hydra`)	Los controles cerrados son exactamente los que limitan intentos y acceso remoto
H-08	T1190: SQLi en `consultas.php`	AppArmor reduce el impacto si el proceso web se compromete
H-11	Fuerza bruta contra cuentas Windows	El bloqueo de cuenta es el equivalente Windows de `MaxAuthTries`
H-09	Disco lleno del manager (F5)	Relación indirecta: la separación de logs protege el disco de los agentes; el incidente del manager fue por `vd_updater` y requiere otra remediación
H-14	Acceso no autorizado / disuasión	El mensaje legal es un control disuasivo y de cumplimiento

6. Hardening aplicado (requisito 4)

6.1 Criterios de selección

No se aplicó el benchmark completo. Se seleccionaron controles de **CIS Level 1** con tres criterios: impacto directo en la superficie de ataque, bajo riesgo de dejar el sistema inaccesible y verificabilidad por SCA. Se incluyó una excepción de **Level 2** (`1.6.1.4`, AppArmor profiles enforcing) porque el confinamiento de procesos es central para el hallazgo H-08 y su aplicación fue estable.

El hardening se aplicó **después** de capturar la evidencia de F5. Esa secuencia es deliberada y se explica en la sección 1.3.

6.2 Linux: configuración SSH verificada

La tabla siguiente muestra el estado final que el SCA post-hardening confirmó en `agent-linux` y `agent-db`. Los dos agentes comparten la misma política SSH y los mismos controles.

Control CIS	Configuración	Valor verificado	Estado SCA
`5.2.1`	Permisos de `/etc/ssh/sshd_config`	Propietario `root:root`, sin lectura para grupo/otros	Aprobado
`5.2.7`	`PermitRootLogin`	`no`	Aprobado
`5.2.12`	`X11Forwarding`	`no`	Aprobado
`5.2.16`	`AllowTcpForwarding`	`no`	Aprobado
`5.2.18`	`MaxAuthTries`	`4`	Aprobado
`5.2.19`	`MaxStartups`	`10:30:60`	Aprobado
`5.2.21`	`LoginGraceTime`	`60`	Aprobado

Procedimiento reproducible. Los comandos siguientes reproducen el estado verificado; la evidencia es el CSV post-hardening. Antes de recargar SSH, validar la sintaxis con `sshd -t` para no cortar el acceso.

```
# Respaldar la configuración antes de tocarla
cp -a /etc/ssh/sshd_config /etc/ssh/sshd_config.bak.$(date +%F)

# Aplicar los valores y validar sintaxis
sed -i 's/^#\?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
sed -i 's/^#\?MaxAuthTries.*/MaxAuthTries 4/' /etc/ssh/sshd_config
sed -i 's/^#\?X11Forwarding.*/X11Forwarding no/' /etc/ssh/sshd_config
sed -i 's/^#\?AllowTcpForwarding.*/AllowTcpForwarding no/' /etc/ssh/sshd_config
grep -q '^MaxStartups' /etc/ssh/sshd_config || echo 'MaxStartups 10:30:60' >> /etc/ssh/sshd_config
grep -q '^LoginGraceTime' /etc/ssh/sshd_config || echo 'LoginGraceTime 60' >> /etc/ssh/sshd_config
chown root:root /etc/ssh/sshd_config
chmod og-rwx /etc/ssh/sshd_config
sshd -t && systemctl reload ssh
```

6.3 Linux: AppArmor y permisos

En `agent-linux`, AppArmor ya estaba instalado pero los perfiles no estaban en enforcing; en `agent-db` faltaba el paquete. Después del hardening, los dos agentes tienen `1.6.1.1` (instalado) y `1.6.1.4` (perfiles enforcing) aprobados.

```
apt-get update && apt-get install -y apparmor apparmor-utils
aa-enforce /etc/apparmor.d/*
apparmor_status | grep -E 'profiles are loaded|profiles are in enforce mode'
```

El estado de AppArmor y de los permisos de `sshd_config` se verificó con el SCA post-hardening. No se tocaron otros archivos de configuración fuera del alcance de los hallazgos.

6.4 Windows: políticas de grupo aplicadas

En `agent-windows` se configuró política de grupo local (por ejemplo, con `gpedit.msc` o `secedit`), ya que el laboratorio no tiene un controlador de dominio dedicado a GPOs. La tabla siguiente resume el estado verificado.

Control CIS	Política	Valor verificado	Estado SCA
`1.1.4`	Minimum password length	14 caracteres	Aprobado
`1.2.1`	Account lockout duration	15 minutos	Aprobado
`1.2.2`	Account lockout threshold	5 intentos	Aprobado
`1.2.4`	Reset account lockout counter	15 minutos	Aprobado
`2.3.7.3`	Machine inactivity limit	900 segundos	Aprobado
`2.3.7.5`	Interactive logon: Message title	Configurado	Aprobado
`2.3.7.4`	Interactive logon: Message text	Configurado	Aprobado*
`2.3.1.2`	Accounts: Guest account status	Disabled	Aprobado*

Procedimiento reproducible. La ruta es `Computer Configuration → Windows Settings → Security Settings → Account Policies` para contraseña y bloqueo, y `Local Policies → Security Options` para inactividad, mensaje legal y Guest. En un entorno con dominio, esto se haría con una GPO centralizada; en este laboratorio, con política local.

* `2.3.7.4` y `2.3.1.2` se verificaron por inspección directa del sistema el 04/11/2026, posterior al CSV post-hardening del 03/11; aún no se confirmaron con un nuevo escaneo SCA.

6.5 Lo que deliberadamente no se aplicó

Elemento	CIS	Motivo	Plan
`AllowUsers` / `AllowGroups`	`5.2.4`	Requiere inventario de usuarios autorizados; un error deja fuera al equipo	Definir la lista en una ventana de cambio y probar con una sesión de rescate
Contraseña de GRUB	`1.4.1`	Requiere consola y reinicio; un hash mal aplicado puede impedir el arranque	Programar con backup de `/boot/grub/grub.cfg`
Particiones separadas de logs	`1.1.5.1`, `1.1.6.1`	Requiere reparticionar o reinstalar; no se hace en caliente	Incluir en el próximo rebuild; mientras tanto, rotación y envío remoto
AppArmor en el bootloader	`1.6.1.2`	Requiere editar la línea de arranque y reiniciar	Ventana de mantenimiento

6.6 Verificación y control de cambios

Cada cambio se validó con el SCA post-hardening. No se detectaron regresiones: ningún control que estuviera aprobado antes pasó a fallido después. Esa es la prueba más fuerte de que el hardening no rompió controles existentes. La verificación es el resultado del SCA y el repositorio conserva los CSV.

Sobre el alcance Level 1. El enunciado pide "hardening básico siguiendo los benchmarks CIS Level 1". Se aplicó un subconjunto priorizado de Level 1, más la excepción Level 2 de AppArmor. No se aplicó el benchmark completo ni se ejecutó un script de hardening masivo. Un script así, sobre una VM compartida, puede dejar el sistema inaccesible y no permite verificar el efecto de cada cambio.

7. Resultados después del hardening (requisito 4, verificación)

7.1 Antes y después por agente

Los puntajes antes/después por agente (182/198/359 controles; 38.9→43.3%, 41.5→46.6%, 39.3→40.9%) ya están en "Resumen de resultados", al inicio del informe.

El agregado de controles pasó de 284/715 (39.7%) a 307/715 (42.9%). Es una mejora modesta pero real, y sobre todo **sin regresiones**.

7.2 Controles ganados

Se ganaron **23 controles** en total: 8 en `agent-linux`, 9 en `agent-db` y 6 en `agent-windows`. El listado completo, con el título de cada control, está en el anexo B.

7.3 Regresiones y estabilidad

0 regresiones. Ningún control que estuviera aprobado en la línea base pasó a fallido después del hardening. La comparación se hizo por ID CIS y cubrió los tres agentes. Los 739 controles evaluados se mantuvieron estables entre ambas mediciones.

7.4 Cobertura por framework

Framework	agent-linux	agent-db	agent-windows
PCI DSS v4.0	36.9% → 41.2% (+4.3 pp)	41.8% → 46.8% (+5.0 pp)	38.6% → 41.1% (+2.5 pp)
PCI DSS v3.2.1	38.5% → 43.5% (+5.0 pp)	42.1% → 47.8% (+5.7 pp)	38.4% → 38.8% (+0.4 pp)
HIPAA	38.6% → 41.0% (+2.4 pp)	34.5% → 38.1% (+3.6 pp)	57.9% → 60.5% (+2.6 pp)
NIST 800-53	34.4% → 39.7% (+5.3 pp)	32.8% → 38.9% (+6.1 pp)	48.7% → 49.3% (+0.6 pp)
ISO 27001	37.5% → 41.7% (+4.2 pp)	40.9% → 45.7% (+4.8 pp)	37.0% → 39.1% (+2.1 pp)
SOC 2	36.7% → 41.8% (+5.1 pp)	41.6% → 47.4% (+5.8 pp)	37.3% → 37.8% (+0.5 pp)
CMMC v2.0	38.9% → 43.7% (+4.8 pp)	42.2% → 47.6% (+5.4 pp)	37.9% → 40.3% (+2.4 pp)
CIS CSC v8	38.0% → 42.7% (+4.7 pp)	41.7% → 47.0% (+5.3 pp)	38.5% → 40.5% (+2.0 pp)

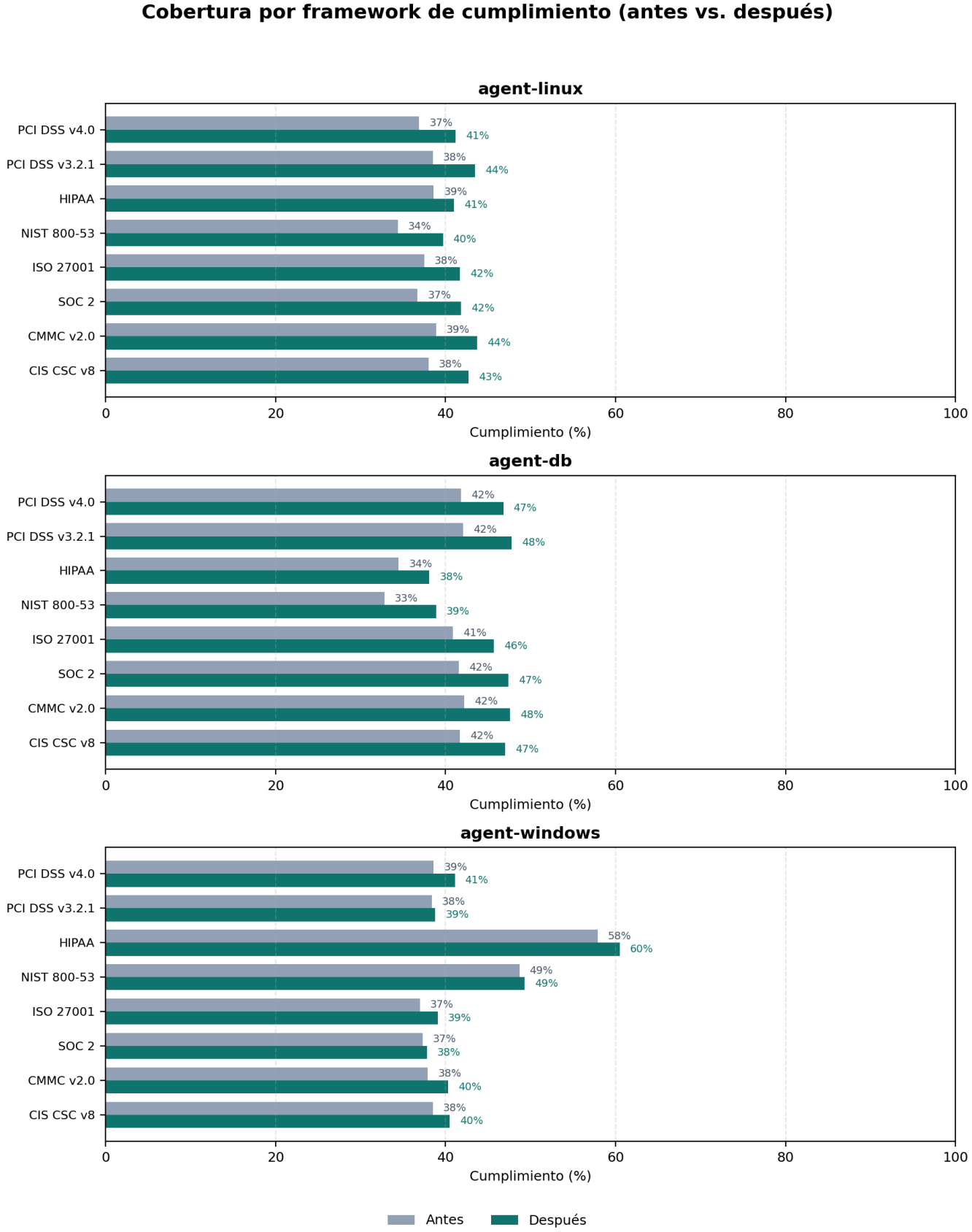


Figura 1. Cobertura por framework antes y después.

La mejora es consistente en los ocho frameworks, aunque de magnitud distinta. Los mayores saltos están en NIST 800-53 de `agent-db` (+6.1 pp) y en PCI DSS v3.2.1 de `agent-db` (+5.7 pp), porque los controles SSH y AppArmor están mapeados a varios requisitos de esos frameworks. En `agent-windows`, PCI DSS v3.2.1 casi

no se movió (+0.4 pp) porque los controles ganados están mapeados sobre todo a PCI DSS v4.0, HIPAA y CMMC.

7.5 Distribución de fallos por sección

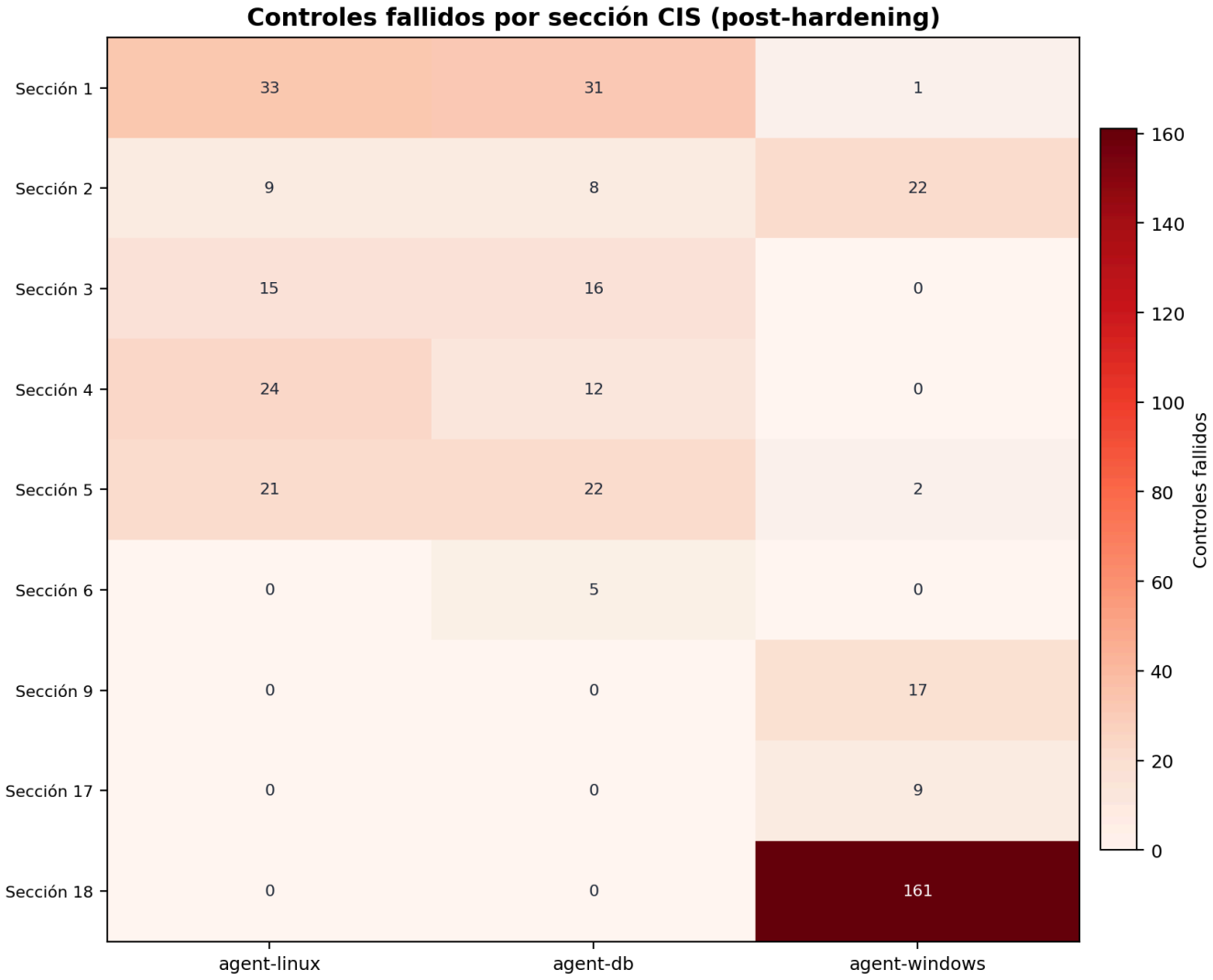


Figura 2. Controles fallidos por sección CIS después del hardening.

La figura muestra que el problema residual no está distribuido de forma uniforme. En `agent-windows`, la sección 18 es un bloque enorme; en los Linux, las secciones 1, 3 y 4 concentran la deuda estructural. Esa lectura es la que guía la hoja de ruta de la sección 8.

7.6 Estado de los hallazgos

Nueve hallazgos quedaron resueltos, uno parcial y cuatro pendientes. La diferencia entre “resuelto” y “score alto” es importante: los 23 controles ganados no mueven el score global a un valor alto porque el benchmark tiene cientos de controles. El valor del hardening está en qué controles se cerraron, no solo en cuántos puntos subió el porcentaje.

7.7 Interpretación

Por qué Linux subió más que Windows. En `agent-linux` y `agent-db` los controles cerrados son 8 y 9, sobre 180 y 176 controles evaluables respectivamente: eso explica saltos de +4.4 pp y +5.1 pp. En `agent-windows` se cerraron 6 controles sobre 359, lo que da +1.6 pp. El tamaño del denominador importa: un mismo esfuerzo mueve menos el score cuando el benchmark tiene más checks.

Por qué el score no es la única métrica. Un control como `PermitRootLogin no` vale lo mismo que "no mostrar el último usuario" en el score, aunque el primero cierra un vector de root remoto y el segundo es cosmético. Por eso el informe prioriza por hallazgos y por secciones, no solo por porcentaje.

Qué significa el resultado para el negocio. El laboratorio pasó de un estado basal vulnerable a un estado con los vectores de acceso remoto principales cerrados. No es un sistema certificado, pero es un sistema con menos puertas abiertas y con evidencia de que los cambios se aplicaron.

8. Brechas residuales y hoja de ruta

8.1 Linux: deuda estructural

Los controles que siguen fallando en `agent-linux` y `agent-db` se pueden agrupar en cinco bloques: particiones separadas, arranque (GRUB y AppArmor), firewall, auditoría (`auditd`) y acceso SSH (`AllowUsers`, banner, timeout y bloqueo PAM). La tabla prioriza los de mayor impacto.

CIS	Brecha	agent-linux	agent-db	Control
`1.1.5.1`	Partición separada para `/var/log`	Fallido	Fallido	Ensure separate partition exists for /var/log.
`1.1.6.1`	Partición separada para `/var/log/audit`	Fallido	Fallido	Ensure separate partition exists for /var/log/audit.
`1.1.2.1`	Partición separada para `/tmp`	Fallido	Fallido	Ensure /tmp is a separate partition.
`1.1.3.1`	Partición separada para `/var`	Fallido	Fallido	Ensure separate partition exists for /var.
`1.1.4.1`	Partición separada para `/var/tmp`	Fallido	Fallido	Ensure separate partition exists for /var/tmp.
`1.1.7.1`	Partición separada para `/home`	Fallido	Fallido	Ensure separate partition exists for /home.
`1.4.1`	Contraseña de GRUB	Fallido	Fallido	Ensure bootloader password is set.
`1.6.1.2`	AppArmor en el bootloader	Fallido	Fallido	Ensure AppArmor is enabled in the bootloader configuration.
`3.5.1.3`	Servicio `ufw` habilitado	Fallido	Fallido	Ensure ufw service is enabled.
`3.5.1.7`	Política por defecto `deny` en `ufw`	Fallido	Fallido	Ensure ufw default deny firewall policy.
`4.1.1.1`	`auditd` instalado	Fallido	Fallido	Ensure auditd is installed.

CIS	Brecha	agent-linux	agent-db	Control
`4.1.1.2`	`auditd` habilitado y activo	Fallido	Fallido	Ensure auditd service is enabled and active.
`5.2.4`	Acceso SSH limitado	Fallido	Fallido	Ensure SSH access is limited.
`5.2.17`	Banner SSH	Fallido	Fallido	Ensure SSH warning banner is configured.
`5.2.22`	Timeout de inactividad SSH	Fallido	Fallido	Ensure SSH Idle Timeout Interval is configured.
`5.4.2`	Bloqueo de PAM tras intentos fallidos	Fallido	Fallido	Ensure lockout for failed password attempts is configured.

Lectura. Las particiones y GRUB son deuda de instalación, no de configuración en caliente. El firewall y `auditd` son deuda de configuración y deberían cerrarse antes que las particiones: un sistema sin firewall y sin auditoría tiene menos visibilidad y menos contención que un sistema con logs en el mismo disco. `AllowUsers`, el banner y el timeout SSH son quick wins de la próxima ventana.

8.2 Windows: plantillas administrativas y auditoría

En `agent-windows` la deuda está dominada por la sección 18. No todo lo que falla ahí es crítico: muchas son plantillas de experiencia de usuario, telemetría o navegador. Pero hay controles de seguridad relevantes mezclados. La tabla separa lo que sí importa.

CIS	Brecha	Estado	Control
`1.1.6`	Permitir contraseñas más largas (relax minimum length)	Fallido	Ensure 'Relax minimum password length limits' is set to 'Enabled'.
`5.1`	Print Spooler deshabilitado (DC)	Fallido	Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (DC only).
`5.2`	Print Spooler deshabilitado (MS)	Fallido	Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (MS only).
`9.1.5`	Logging de firewall de dominio	Fallido	Ensure 'Windows Firewall: Domain: Logging: Name' is set to '%SystemRoot%.log'.
`9.1.6`	Tamaño del log de firewall	Fallido	Ensure 'Windows Firewall: Domain: Logging: Size limit (KB)' is set to '16,384 KB or greater'.
`9.1.7`	Registro de paquetes descartados	Fallido	Ensure 'Windows Firewall: Domain: Logging: Log dropped packets' is set to 'Yes'.
`9.1.8`	Registro de conexiones exitosas	Fallido	Ensure 'Windows Firewall: Domain: Logging: Log successful connections' is set to 'Yes'.
`17.1.2`	Auditoría de Kerberos	Fallido	Ensure 'Audit Kerberos Authentication Service' is set to 'Success and Failure' (DC Only).
`17.1.3`	Auditoría de tickets Kerberos	Fallido	Ensure 'Audit Kerberos Service Ticket Operations' is set to 'Success and Failure' (DC Only).
`17.4.1`	Auditoría de acceso a Directory Service	Fallido	Ensure 'Audit Directory Service Access' is set to include 'Failure' (DC only).

CIS	Brecha	Estado	Control
`17.4.2`	Auditoría de cambios en Directory Service	Fallido	Ensure 'Audit Directory Service Changes' is set to include 'Success' (DC only).
`18.3.1`	Extensión LAPS instalada	Fallido	Ensure LAPS AdmPwd GPO Extension / CSE is installed (MS only).
`18.3.3`	LAPS habilitado	Fallido	Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (MS only).
`18.4.4`	SMBv1 server deshabilitado	Fallido	Ensure 'Configure SMB v1 server' is set to 'Disabled'.

Lectura. Lo más urgente es SMBv1 server (`18.4.4`), Print Spooler (`5.1`/`5.2`) y LAPS (`18.3.1`/`18.3.3`). El logging de firewall (`9.1.5`-`9.1.8`) no cambia la configuración de bloqueo, pero sí la visibilidad: sin logs no se puede investigar. La auditoría avanzada (`17.x`) es clave en un controlador de dominio. Las plantillas de la sección 18 que no sean de seguridad pueden quedar en un segundo lote.

8.3 agent-db: la sombra de Debian 13

Los 22 N/A de `agent-db` no son controles aprobados: son controles que la política no pudo evaluar. 21 están en la sección 4 (auditoría) y uno en `5.4.1` (requisitos de creación de contraseñas). La causa principal es que `auditd` no está instalado y la política Debian 11 no encuentra las reglas que espera. Además, hay fallos reales en permisos de `/etc/shadow`, `/etc/shadow-`, `/etc/gshadow` y `/etc/gshadow-` (sección 6).

La recomendación es no leer el 46.6% de `agent-db` como "mejor que `agent-linux`". Si se contaran los 21 N/A de auditoría como fallidos, el score sería 41.6% después del hardening, por debajo del 43.3% de `agent-linux`. La comparación honesta es esa.

8.4 Matriz de priorización

Incluye los hallazgos pendientes de la sección 5 (H-02, H-07, H-09) junto con el resto de los controles CIS que siguen fallando, priorizados por esfuerzo e impacto.

Prioridad	Brecha	Agente	Esfuerzo	Impacto	Acción
P1	`5.2.4` AllowUsers	Linux	Bajo	Alto	Definir lista y probar con sesión de rescate
P1	`5.2.17` banner SSH	Linux	Bajo	Medio	Configurar `Banner /etc/issue.net`
P1	`5.2.22` timeout SSH	Linux	Bajo	Medio	`ClientAliveInterval` y `ClientAliveCountMax`
P1	`5.4.2` bloqueo PAM	Linux	Bajo	Alto	`pam_faillock` o `pam_tally2`
P1	`4.1.1.1`/`4.1.1.2` auditd	Linux	Medio	Alto	Instalar, habilitar y cargar reglas
P1	`3.5.1.3`/`3.5.1.7` firewall	Linux	Medio	Alto	`ufw` o `nftables` con deny por defecto
P1	`18.4.4` SMBv1 server	Windows	Bajo	Alto	Deshabilitar SMBv1 server
P1	`5.1`/`5.2` Print Spooler	Windows	Bajo	Medio	Deshabilitar si no se usa impresión

Prioridad	Brecha	Agente	Esfuerzo	Impacto	Acción
P1	`9.1.5` - `9.1.8` logging firewall	Windows	Bajo	Alto	Configurar log y tamaño
P1	`18.3.1` / `18.3.3` LAPS	Windows	Medio	Alto	Instalar CSE y habilitar LAPS
P2	`17.x` auditoría avanzada	Windows	Medio	Alto	Aplicar baseline de auditoría
P2	`1.4.1` GRUB	Linux	Medio	Alto	Ventana de mantenimiento con backup
P2	`1.6.1.2` AppArmor bootloader	Linux	Medio	Medio	Editar línea de arranque
P3	Particiones separadas	Linux	Alto	Medio	Rebuild del laboratorio
P3	Plantillas 18.x no críticas	Windows	Alto	Bajo/Medio	Lote posterior, por excepción

8.5 Riesgo residual y controles compensatorios

El riesgo residual no es cero. Los controles compensatorios que hoy existen son: segmentación de red del laboratorio, monitoreo centralizado con Wazuh, FIM en archivos críticos, Active Response para fuerza bruta SSH y la evidencia de F5 que demuestra que los ataques principales son detectados (con las brechas ya documentadas). Estos controles no sustituyen el hardening pendiente, pero reducen la probabilidad y el impacto mientras se cierra.

8.6 Trabajo futuro

1. Cerrar los P1 de la matriz en una ventana de cambio y volver a medir con SCA.
2. Reconstruir el laboratorio con particiones separadas para `/var/log` y `/var/log/audit`.
3. Incorporar el agente MISP al alcance de SCA o documentarlo formalmente como fuera de alcance.
4. Convertir el análisis antes/después en una tarea programada: guardar CSV con fecha y comparar.
5. Evaluar una política CIS Debian 13 cuando Wazuh la publique, para eliminar la adaptación.
6. Agregar una prueba de regresión de configuración en el pipeline de despliegue.

9. Conclusiones

9.1 Cumplimiento de los cinco requisitos

Los cinco requisitos están cumplidos, con la evidencia y la sección que sostiene cada uno resumidas en la tabla de la introducción.

9.2 Resultados principales

- Los tres agentes mejoraron: `agent-linux` +4.4 pp, `agent-db` +5.1 pp y `agent-windows` +1.6 pp.
- Se ganaron 23 controles y no se perdió ninguno.
- Se cerraron controles SSH que limitan la fuerza bruta y el acceso remoto; la demo de F5 usó una contraseña débil de prueba.

- Se cerraron las políticas de contraseña, bloqueo e inactividad de Windows.
- Quedan 3 hallazgos pendientes, todos priorizados.
- El score sigue siendo bajo y describe configuración.

9.3 Alcance de las conclusiones

Estas conclusiones describen la configuración medida en tres agentes en dos fechas. La línea base, los cambios verificados y la mejora cuantificada son el aporte del informe; la certificación formal y la auditoría de cumplimiento quedan fuera del alcance de la fase. La lista de controles pendientes completa el cuadro y marca el trabajo que sigue.

10. Referencias

[1] Wazuh Inc., "Security Configuration Assessment," *Wazuh Documentation 4.9*. [Online]. Available: https://documentation.wazuh.com/4.9/user-manual/capabilities/sec-config-assessment/. [Accessed: 04-Nov-2026].

[2] Wazuh Inc., "Regulatory Compliance," *Wazuh Documentation 4.9*. [Online]. Available: https://documentation.wazuh.com/4.9/user-manual/capabilities/regulatory-compliance/. [Accessed: 04-Nov-2026].

[3] Wazuh Inc., "SCA policies," *wazuh-ruleset*. [Online]. Available: https://github.com/wazuh/wazuh-ruleset. [Accessed: 04-Nov-2026].

[4] Wazuh Inc., "Wazuh 4.9.2 release notes," *Wazuh Documentation*. [Online]. Available: https://documentation.wazuh.com/4.9/release-notes/release-4-9-2.html. [Accessed: 04-Nov-2026].

[5] CIS, "CIS Ubuntu Linux 22.04 LTS Benchmark," Version 1.0.0, Aug. 30, 2022.

[6] CIS, "CIS Debian Linux 11 Benchmark," Version 1.0.0, Sep. 22, 2022.

[7] CIS, "CIS Microsoft Windows Server 2022 Benchmark," Version 2.0.0, Apr. 14, 2023.

[8] PCI Security Standards Council, "PCI DSS v4.0," PCI SSC, 2022. [Online]. Available: https://www.pcisecuritystandards.org/. [Accessed: 04-Nov-2026].

[9] U.S. Department of Health & Human Services, "HIPAA Security Rule," HHS. [Online]. Available: https://www.hhs.gov/hipaa/. [Accessed: 04-Nov-2026].

[10] NIST, "Security and Privacy Controls for Information Systems and Organizations," Special Publication 800-53 Rev. 5, Sep. 2020. [Online]. Available: https://csrc.nist.gov/. [Accessed: 04-Nov-2026].

[11] European Parliament and Council, "Regulation (EU) 2016/679 (General Data Protection Regulation)," *Official Journal of the European Union*, 2016. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2016/679/oj. [Accessed: 04-Nov-2026].

[12] MITRE, "ATT&CK Enterprise Matrix." [Online]. Available: https://attack.mitre.org/. [Accessed: 04-Nov-2026].

[13] Center for Internet Security, "CIS Critical Security Controls v8," CIS, 2021. [Online]. Available: https://www.cisecurity.org/controls/. [Accessed: 04-Nov-2026].

[14] Proyecto, "F5: simulación de ataques y tasa de detección," Informe técnico, Fase 5, 2026. `F5_Informe_Ataques_Deteccion.md`.

[15] Proyecto, "F6: datos congelados del análisis SCA," Documento de trabajo, 2026. `F6_Assets/ANALISIS_DATOS.md`.

Anexo A: Inventario de evidencia

Los seis CSV son la evidencia primaria; el análisis agregado está en `F6_Assets/ANALISIS_DATOS.md` [15]. La tabla incluye filas, distribución aprobado/fallido/N/A y hash SHA-256 (primeros 16 caracteres, para identificar el archivo exacto sin reproducir el hash completo).

Archivo	Agente	Fase	Filas	P/F/N/A	SHA-256
`Configuration-Assestments/checks_agente-linux.csv`	agent-linux	Antes	182	70/110/2	fd1ac1794235d3a0…
`Configuration-Assestments-PostHardening/checks_agente-linux.csv`	agent-linux	Después	182	78/102/2	2cf946c95d5fe7c2…
`Configuration-Assestments/checks_db.csv`	agent-db	Antes	198	73/103/22	366ee8ae0965cd14…
`Configuration-Assestments-PostHardening/checks_db.csv`	agent-db	Después	198	82/94/22	fd415ac60d5aef15…
`Configuration-Assestments/checks_windows.csv`	agent-windows	Antes	359	141/218/0	c81d78573ca84972…
`Configuration-Assestments-PostHardening/checks_windows.csv`	agent-windows	Después	359	147/212/0	fb604f671087012a…

Anexo B: Controles ganados

B.1 agent-linux

CIS	Control
`1.6.1.4`	Ensure all AppArmor Profiles are enforcing.
`5.2.1`	Ensure permissions on /etc/ssh/sshd_config are configured.
`5.2.7`	Ensure SSH root login is disabled.
`5.2.12`	Ensure SSH X11 forwarding is disabled.
`5.2.16`	Ensure SSH AllowTcpForwarding is disabled.
`5.2.18`	Ensure SSH MaxAuthTries is set to 4 or less.
`5.2.19`	Ensure SSH MaxStartups is configured.
`5.2.21`	Ensure SSH LoginGraceTime is set to one minute or less.

B.2 agent-db

CIS	Control
`1.6.1.1`	Ensure AppArmor is installed.

CIS	Control
1.6.1.4	Ensure all AppArmor Profiles are enforcing.
5.2.1	Ensure permissions on /etc/ssh/sshd_config are configured.
5.2.7	Ensure SSH root login is disabled.
5.2.12	Ensure SSH X11 forwarding is disabled.
5.2.16	Ensure SSH AllowTcpForwarding is disabled.
5.2.18	Ensure SSH MaxAuthTries is set to 4 or less.
5.2.19	Ensure SSH MaxStartups is configured.
5.2.21	Ensure SSH LoginGraceTime is set to one minute or less.

B.3 agent-windows

CIS	Control
1.1.4	Ensure 'Minimum password length' is set to '14 or more character(s)'.
1.2.1	Ensure 'Account lockout duration' is set to '15 or more minute(s)'.
1.2.2	Ensure 'Account lockout threshold' is set to '5 or fewer invalid logon attempt(s), but not 0'.
1.2.4	Ensure 'Reset account lockout counter after' is set to '15 or more minute(s)'.
2.3.7.3	Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0'.
2.3.7.5	Configure 'Interactive logon: Message title for users attempting to log on'.

Anexo C: Benchmarks y PDFs locales

Durante la fase se consultaron PDFs de CIS como referencia local. No todos corresponden a la versión que Wazuh ejecutó. La clasificación es la siguiente.

Archivo	Qué es	¿Se usa para mapear IDs?
CIS_Ubuntu_Linux_22.04_LTS_Benchmark_v3.0.0.pdf	Benchmark estándar v3.0.0 (2025-10-30)	No. La numeración cambió respecto de v1.0.0; solo referencia general
CIS_Ubuntu_Linux_22.04_LTS_STIG_Benchmark_v1.0.0.pdf	STIG v1.0.0	No. Es otro benchmark
CIS_Debian_Linux_11_Benchmark_v1.0.0_ARCHIVE.pdf	Benchmark Debian 11 v1.0.0	Sí, para `agent-db`, con la adaptación a Debian 13
CIS_Microsoft_Windows_Server_2022_Benchmark_v5.1.0.pdf	Benchmark estándar v5.1.0	No. Es más nuevo que el v2.0.0 usado por Wazuh
CIS_Microsoft_Windows_Server_2022_Stand-alone_Benchmark_v2.0.0.pdf	Stand-alone v2.0.0	No. Es otro benchmark
CIS_Microsoft_Windows_Server_2022_STIG_Benchmark_v1.0.0-ARCHIVE.pdf	STIG v1.0.0 (archivo)	No. Es otro benchmark
CIS_Microsoft_Windows_Server_2022_STIG_Benchmark_v2.0.0.pdf	STIG v2.0.0	No. Es otro benchmark

Las versiones exactas que Wazuh usa están en la tabla de la sección 2.2. Los PDF exactos de Ubuntu v1.0.0 y Windows v2.0.0 no están en el repositorio; se citan a través del YAML de Wazuh.

Licencia. Los benchmarks de CIS están protegidos por sus términos de uso y no se redistribuyen.

Anexo D: Exportación desde el dashboard

D.1 Qué exporta Wazuh 4.9.2

En Wazuh 4.9.2, la vista de **Security Configuration Assessment** exporta los resultados en **CSV** (`Export formatted` y `Export raw`). La evidencia primaria de este entregable son los seis CSV exportados desde el dashboard; este PDF se construyó a partir de ellos con Pandoc y Chrome headless.

D.2 Procedimiento de exportación CSV

```
Wazuh Dashboard → Agents → seleccionar agente
  → Security Configuration Assessment → política CIS
  → Export formatted (CSV)
  → guardar como Configuration-Assestments/checks_<agente>.csv
```

Para la línea base se usó `Configuration-Assestments/`. Para la segunda medición se usó `Configuration-Assestments-PostHardening/`, con los mismos nombres de archivo para facilitar la comparación.

D.3 Los PDF de `Wazuh-Reportes/`

Los cuatro PDF que están en `Wazuh-Reportes/` son exportaciones del panel **Agent Configuration** (configuración del agente: `ossec.conf`, módulos activos, etc.), no del panel SCA. No se usan como evidencia de cumplimiento. Se dejan en el repositorio porque documentan la configuración del agente, pero se aclara su naturaleza para evitar confusiones.

Anexo E: Glosario

Término	Definición
SCA	Security Configuration Assessment: módulo de Wazuh que evalúa la configuración contra una política
CIS	Center for Internet Security: organización que publica benchmarks de hardening
Benchmark	Guía de configuración segura con controles numerados y perfiles Level 1/Level 2
Level 1	Perfil de hardening base, aplicable a la mayoría de los sistemas
Level 2	Perfil más estricto, para entornos de alta seguridad
PCI DSS	Estándar de seguridad para datos de tarjetas de pago
HIPAA	Ley de protección de información de salud de EE. UU.
NIST SP 800-53	Catálogo de controles de seguridad y privacidad del NIST
GDPR	Reglamento General de Protección de Datos de la UE
GPO	Group Policy Object: política de grupo de Windows

Término	Definición
FIM	File Integrity Monitoring: monitoreo de integridad de archivos de Wazuh
N/A	Not applicable: el check no pudo evaluarse en ese sistema

---

Documento generado el 03/11/2026 a partir de `F6_Assets/analysis.json` y de los seis CSV de SCA.